# Trust is repaired, not revoked

Containment is the correct first response to a trust failure. It is not the last one, and the absence of a route back is what makes both ends of the trust spectrum unworkable.

ABSTRACT

When an agent violates the behavior expected of it, the correct immediate response is containment: quarantine, reduction of scope, suspension of specific tool grants, escalation to a human. This note takes that as settled and addresses the question that follows it, which is on what basis the agent resumes, and what has to be true before it does.

The argument is that unconditional transitive trust and zero standing trust are the two ends of a single spectrum, and that both carry performance and security costs that are usually discussed as though only one end had them. The workable position is between them, where trust is measured continuously and enforcement responds to conditions as they change. A system of that kind requires a defined route back from a trust failure, because a containment action with no route back is not a stricter control. It is a control that gets bypassed.

## 1. What this note does not argue

The title is a claim about what happens after containment, not a claim against containment. It is worth stating the negative case explicitly, because the compressed version of this argument is frequently misread as leniency.

Nothing here suggests that a trust failure should be met with a lighter response, that an agent exhibiting anomalous behavior should retain its authority while the matter is investigated, or that revocation of a specific permission is the wrong instrument. Containment should be immediate, it should be automatic where the violation class permits automation, and it should err toward over-containment, because the cost of wrongly containing a well-behaved agent is delay while the cost of failing to contain a misbehaving one is unbounded.

The argument is narrower. Containment stops exposure. It does not establish anything about what should happen next, and in most deployments the question of what happens next has no defined answer at all. The agent sits quarantined until somebody decides, informally and usually under delivery pressure, to turn it back on. That decision is the actual trust decision, and it is almost always made without evidence, without a record, and without anybody having to say what would have changed their mind.

## 2. Two ends of one spectrum

Discussions of agent authority tend to position two models as opposites rather than as endpoints of a continuum, which obscures the fact that they fail in structurally similar ways.

### 2.1 Unconditional transitive trust

Trust extends through endorsement. A platform is approved, so the agents running on it are approved. A vendor is on the approved list, so its integration inherits the standing of the review that approved the vendor. An agent is granted a credential at provisioning time and holds it until somebody takes it away.

The appeal is performance. There is no per-action cost, no verification latency, and no friction in the common case, which is the overwhelming majority of actions. The security cost is that authority travels further than the evidence supporting it. The endorsement was based on an evaluation of one thing, and the authority now attaches to another thing several steps removed, with no mechanism that weakens the inheritance as it moves. A compromise anywhere in the chain carries the full weight of the original endorsement, and the parties relying on it have no way to tell how far from direct evidence their reliance has drifted.

### 2.2 Zero standing trust

The opposing model holds that no actor should carry authority by virtue of position, identity or prior approval, and that every request should be authorized on its own terms against current policy.

As an architectural principle this is sound, and the critique that produced it was correct: implicit trust derived from network position was the cause of a long sequence of expensive failures. The argument here is not against that principle. It concerns what happens when the model is used as the complete account of an agent's ongoing authority, which is a use it was not designed for.

Two problems arise at that point. The first is performance, and it is not incidental. A human user authenticates occasionally and then works. An agent may issue thousands of tool calls in the course of a single task, and a model that treats every one as an independent authorization event makes verification the dominant cost of operation rather than an overhead on it.

The second problem is the more serious one, because it concerns what the verification establishes. Per-request authorization answers whether this request is permitted by current policy. It does not answer whether this agent is currently behaving the way it has historically behaved, because a request evaluated in isolation carries no history. An agent that has been compromised and is issuing individually permitted requests in an unprecedented pattern passes every check. The sequence is the signal, and a model that evaluates only the request has discarded it.

There is also an operational failure mode treated in section 7: strict controls with no graduated response tend to be relaxed by the people who have to work under them, which means the realized security of the model is lower than its design.

TABLE 1 · COSTS AT EACH END OF THE SPECTRUM

| MODEL | PERFORMANCE COST | SECURITY COST |
|---|---|---|
| **Unconditional transitive trust** | Low by design. No verification in the common path, which is why it persists despite being known to be unsafe. | Authority outruns evidence. Endorsement is inherited at full strength regardless of distance from direct observation, so one compromise propagates along the whole chain. |
| **Zero standing trust** | High and proportional to activity. An agent issuing thousands of calls per task pays verification on every one, so cost scales with the work rather than with the risk. | Each request is evaluated without history, so a compromised agent issuing individually permitted calls in an anomalous sequence passes. Cost also drives practical relaxation, lowering realized security below designed security. |
| **Measured dynamic trust** | Proportional to risk rather than to volume. Routine action against an established baseline stays cheap; cost concentrates where behavior is unusual. | Depends on baseline quality and on the integrity of the measurement itself, which becomes a target. Covered in section 8. |

### 2.3 The middle is not a compromise between the two

The position between these ends is often described as a balance, as though it accepted some of the risk of one in exchange for some of the convenience of the other. That is not the structure of the claim.

Both ends fail for the same underlying reason, which is that each fixes the trust decision at a single moment. Unconditional trust fixes it at the point of endorsement and never revisits it. Zero standing trust fixes it at the moment of each request and never accumulates. Neither carries a representation of the agent's behavior over time, and so neither can respond to the fact that an agent's behavior has changed. One cannot see the change because it stopped looking; the other cannot see it because it never looks at more than one action.

Measured dynamic trust is a different structure rather than a midpoint on the same axis. Trust is held as a current quantity, derived from the agent's own observed history, and it is evaluated at the moment of enforcement rather than at provisioning time or in isolation. That is what makes a graduated response possible, and a graduated response is what makes repair meaningful: if the only available states are full authority and none, there is nothing for repair to move between. The requirements for such a measure are treated separately in Measuring trust in agentic systems; this note assumes them and takes up what happens when the measure drops.

## 3. Containment is the first move

When behavior falls outside the expected range, the response is to contain, and the containment should be proportionate to what was violated rather than uniform. A system with one response to every class of anomaly will either over-apply it, in which case it gets switched off, or under-apply it, in which case it fails when it matters.

Proportionate containment has a range: suspending a specific tool grant while leaving the rest of the agent operational, reducing scope to a read-only subset, requiring human confirmation on a class of action that previously ran autonomously, routing the agent's output to review rather than to its usual consumer, or full quarantine where the violation class or the blast radius warrants it. These are different instruments and they are not interchangeable.

What containment accomplishes is bounded and worth stating precisely. It stops the current exposure and it buys time to investigate. It establishes nothing about cause, it establishes nothing about whether the behavior will recur, and it establishes nothing about what the agent's authority should be tomorrow. Those are separate findings that require separate work, and the gap between containment and that work is where most agentic governance currently ends.

## 4. Diagnosis before repair

Before repair is the right question, the failure has to be classified, because one of the two common classes does not call for repair at all.

In a **scope failure**, the agent encountered conditions outside the context it was deployed for and behaved in a way that was reasonable given those conditions and unacceptable given its mandate. The agent did not change. The accuracy of the statement describing where it was supposed to operate was always wrong, and the deployment only now discovered it. The trust relationship is not damaged by this, and treating the agent as the thing requiring remediation produces a fix aimed at the wrong target. The correct remedy is to the scope definition and to the controls that allowed the agent to be presented with inputs outside it.

In a **model failure**, behavior degraded inside the intended scope. The agent was presented with conditions it was supposed to handle and did not handle them in the way its established pattern predicted. This damages the trust relationship, because the basis on which authority was extended was the expectation of a behavioral range, and the behavior left that range under conditions that were supposed to be covered.

Conflating these is expensive in both directions. Treating a scope failure as a model failure sends teams to retrain or replace an agent that was working correctly, leaves the actual scope gap open, and produces a second incident with the same root cause and a different agent. Treating a model failure as a scope failure produces a scope restriction that papers over real degradation and restores authority on the strength of an explanation that does not hold.

## 5. What repair requires

Where the diagnosis is model failure, repair is the process by which authority is re-extended. The human case is instructive here, not as analogy but because the epistemic position is identical. An operator evaluating a corrected agent cannot verify that the correction addressed the cause. They cannot inspect the weights and reach a conclusion, and in most cases they cannot reproduce the original failure on demand. They are in the position of a person receiving an apology: unable to confirm the internal change, able only to assess whether the account is credible and whether subsequent behavior bears it out.

That constraint determines what a repair process can consist of. It cannot consist of verification, because verification is unavailable. It consists of signals whose credibility can be assessed, followed by behavior that either validates them or does not.

### 5.1 Acknowledgment

A record stating that the expected behavior was violated, what the violation was, the scope of what it touched, and the observed impact. This sounds procedural and is load-bearing: an organization that cannot state plainly what its agent did has not completed the investigation, and every subsequent step rests on this one.

### 5.2 Named accountability

Identification of which human actors are responsible for the conditions that allowed the violation. The purpose is ownership rather than blame, and the distinction matters practically: a repair signal attached to no one is not assessable for credibility, because credibility is a property of a source. An anonymous assurance that the problem is fixed carries no information.

### 5.3 Documented change

A specific and auditable description of what was changed, whether in the model, the data, the surrounding controls or the scope, authored by the people who made the change. Specificity is the signal. A description that would be equally true of any remediation of any incident tells the reader that either the cause was never established or the account is being managed.

### 5.4 A validation commitment

A defined period during which the repaired agent runs against a stated behavioral range, with the criteria fixed in advance and the results shared with the parties who relied on it. Fixing the criteria beforehand is what distinguishes validation from the common alternative, which is resuming normal operation and concluding after a quiet fortnight that the matter is closed.

### 5.5 Graduated re-extension rather than restoration

Authority returns in stages, and the stages are tied to accumulated post-incident behavior rather than to elapsed time. This is where a measured trust value does work that a binary permission cannot: it provides the intermediate states for the agent to occupy, so that an agent can be returned to low-risk work while remaining outside its previous authority on the class of action where it failed.

The parallel to the human case holds here too, and it is not sentimental. A colleague who has made a serious error is not generally dismissed and not generally restored to their previous latitude the following morning. They return to work with closer attention on the area where they failed, and the attention relaxes as behavior accumulates. What is being rebuilt is not a feeling. It is a record.

TABLE 2 · FROM VIOLATION TO RESUMED AUTHORITY

| STAGE | WHAT IT ESTABLISHES | WHAT IT DOES NOT ESTABLISH |
|---|---|---|
| **Containment** | Exposure is stopped. Proportionate to violation class, from suspension of a single tool grant through to full quarantine. | Cause, likelihood of recurrence, or what authority is appropriate going forward. |
| **Diagnosis** | Whether this was scope failure or model failure, which determines whether repair is the applicable process at all. | That the remedy will work. Classification directs the remedy; it does not validate it. |
| **Repair signal** | A credible, attributable account of what happened and what changed, assessable by the parties who relied on the agent. | That the change was effective. The signal is evidence about the account, not about the outcome. |
| **Validation** | Post-incident behavior against criteria fixed before the period began. | That the failure cannot recur under conditions not exercised during the period. |
| **Graduated re-extension** | Authority returning in stages, tied to accumulated behavior, with the failure class last to be restored. | A return to the prior position. The incident stays in the record permanently, as section 6 sets out. |

## 6. Repair is not reset

The distinction between repairing an agent and resetting one is the most consequential point in this note, and the common industry response gets it backwards.

The reflex when an agent misbehaves is to tear it down and redeploy from a known-good configuration. Operationally this is attractive: it is fast, it is scriptable, and it produces a system that demonstrably no longer exhibits the behavior. It is also, in trust terms, the worst available option, for two reasons.

The first is evidentiary. The behavioral history is the asset. It is what makes anomaly detection possible, because deviation has no meaning except against an established pattern, and an agent redeployed from a clean image has no pattern. A fresh instance is not a safer instance. It is an instance about which nothing is known, which in a measured-trust system means it has to begin at the authority appropriate to an unknown party, and in most real deployments means it silently inherits the authority its predecessor held.

The second is adversarial, and it is the reason this is a security argument rather than a philosophical one. If containment is reliably followed by reset, then triggering containment becomes a usable technique. An adversary who can induce an agent into an anomalous state can force a redeployment that erases the

accumulated record of their earlier activity, returning the environment to a state where their previous behavior has no trace and the agent's trust posture is at its initial maximum. Reset is not a neutral recovery action under those conditions. It is an outcome worth attacking toward.

Repair restores authority. It does not restore innocence, and the two must be kept distinct in the record. The incident, its classification, the repair signal and the validation outcome persist for the life of the agent, and they form the context within which any subsequent anomaly is read. A second violation of the same class as a repaired first one is a materially different event from a first occurrence, and a system that cannot tell those apart has lost the information that matters most.

> This also sets the standard a repair process has to meet to be worth operating. If repair is slower and more demanding than redeployment while producing the same restored authority, it will not be used. The case for it is that it produces something redeployment cannot: an agent whose current authority rests on evidence, and a record in which the next anomaly can be interpreted.

## 7. Why a terminal control gets bypassed

The practical argument against treating revocation as the end state has nothing to do with being fair to agents. It concerns what people do with controls they cannot live with.

A control whose only outcome is permanent is a control with a high cost of firing. Where that cost falls on a team with delivery commitments, the predictable adaptations follow. Thresholds are raised until alerts stop firing. Critical agents are added to exemption lists on the reasoning that they cannot be allowed to stop. Alerts are routed to a channel nobody reads. The control continues to exist, continues to appear in the architecture diagram, and no longer constrains anything.

This is the mechanism by which strict models underperform their design, and it is why the performance cost in Table 1 is also a security cost. A verification step expensive enough to interfere with the work creates pressure to narrow where it applies, and that pressure is applied continuously by people who are measured on delivery, against a control owned by people who are not in the room.

A graduated response is cheaper to fire. A trust measure that drops and takes a specific tool grant with it imposes a bounded cost, which means the response can actually run, including automatically, including at a threshold low enough to catch things early. The availability of a route back is what makes the containment side usable, which is the sense in which this is an argument for stronger enforcement rather than weaker.

## 8. Limitations and open problems

Several parts of this are unresolved, and the unresolved parts are not peripheral.

- **Authorization of repair is a conflict of interest.** The party best placed to assess a repair signal is usually the party that produced it and is under pressure to restore the agent to service. Separating those roles is a governance design problem that this note does not solve.

- **Repair does not compose across chains.** Where one party's trust in an agent rests partly on a third party's endorsement, it is not clear what repairing the endorser should do to the trust that flowed through it, nor whether an incident at one node should propagate to parties who relied on it indirectly. The attenuation argument makes the forward case; the reverse case is open.
- **Some violation classes should be terminal.** Nothing here implies every failure is repairable. Deliberate circumvention of a control, or a violation touching a category of data where the damage is not recoverable, may warrant permanent withdrawal. Which classes those are is a decision each deployment has to make in advance, since making it during an incident guarantees it is made badly.
- **Repair cadence may lag attack cadence.** A process involving named accountability and a validation period operates on a timescale of days. An adversary operating inside a compromised agent operates on a timescale of seconds. Repair governs the resumption of authority and is not a response to an active intrusion, which remains a containment problem.
- **The measure itself becomes a target.** Once enforcement depends on a trust value, that value is worth attacking, whether by suppressing the signals that would lower it or by shaping behavior during a validation period specifically to pass it. A validation period with criteria fixed in advance is partly a defense against the second case and is not a complete one.

## 9. Summary

When an agent violates its expected behavior, it should be contained, proportionately and immediately. That is the beginning of the process and it is routinely treated as the end of it.

What follows containment is a trust decision: whether this was a failure of scope or of the agent, what account of the failure is credible, what evidence of changed behavior has accumulated, and what authority is warranted now. Unconditional transitive trust cannot make that decision because it stopped evaluating at the point of endorsement. Zero standing trust cannot make it because it evaluates one request at a time and accumulates nothing. Both carry real costs in performance and in security, and the practical failure of the strict end is that its cost drives the relaxation that undermines it.

A measured trust value makes the decision representable, because it supplies the intermediate states between full authority and none. Repair moves an agent through those states on evidence, while the record of what happened persists. The agent returns to work. The incident does not disappear from the history, and the next anomaly is read against it.